

Org-Wide Logging, Auditing and Security Aggregation

Aggregate, make immutable, detect, query. Most designs do the first and forget the second.

An audit log an administrator can delete is not an audit log. **Immutability is the requirement**, not collection.

The organisation trail

- ◆ **One trail, created once, covering every account** including accounts created afterwards.
- ◆ **Member accounts cannot alter or delete it.** They can see it and nothing more.
- ◆ Delegate administration to a security account. **Up to three delegated administrators.**
- ◆ The **management account always owns it**, whoever created it, so removing a delegated admin leaves it intact.

ON THE EXAM

A per-account trail is only as trustworthy as that account's administrator. That is the whole argument for an organisation trail.

Making the logs tamper-evident

- ◆ **A separate Log Archive account** that workload administrators have no access to at all.
- ◆ **S3 Object Lock in compliance mode.** Nobody can delete or overwrite before the retention date. Not even the root user.
- ◆ **Log file integrity validation** produces digest files, so alteration is detectable.
- ◆ An SCP denying deletion is a good layer, and the management account is exempt from it. Module two.

ON THE EXAM

Governance mode can be overridden by a privileged user. Compliance mode cannot. Regulators mean compliance mode.

AWS Config across the organisation

- ◆ **The recorder** captures configuration state and every change, per account and Region.
- ◆ **An aggregator** collects it all into one account for a single compliance view.
- ◆ **Organisation rules and conformance packs** deploy from a delegated administrator to every account at once.
- ◆ **Advanced queries** answer questions across the whole estate, such as which buckets are public.

ON THE EXAM

Config knows what a resource looked like at any moment. CloudTrail knows who changed it. You usually need both.

CloudTrail, Config or CloudWatch?

QUESTION	SERVICE	BECAUSE
Who deleted the bucket?	CloudTrail	It records API calls and callers
What did this look like on Tuesday?	AWS Config	It records state over time
Are any buckets public right now?	AWS Config	Current state, across the estate
Alert me when errors spike	CloudWatch	Alarms evaluate metrics

ON THE EXAM

Who did it means CloudTrail. What it looked like means Config. How it is performing means CloudWatch.

The delegated administrator pattern

- ◆ **Nearly every security service supports it:** CloudTrail, Config, GuardDuty, Security Hub, Macie, Detective, IAM Access Analyzer.
- ◆ It moves daily security work **out of the management account**, which module two said to keep empty.
- ◆ The delegated admin sees findings from every member account, and can enable the service in new accounts automatically.
- ◆ Only the **management account** can appoint or remove one.

ON THE EXAM

Security team needs a full view but must not hold management account credentials is the delegated administrator signature.

The detection stack: who finds what

- ◆ **GuardDuty** finds threats from CloudTrail, DNS and flow logs. Behaviour, not configuration.
- ◆ **Inspector** finds software vulnerabilities and unintended network exposure.
- ◆ **Macie** finds sensitive data in S3. **Detective** investigates a finding after the fact.
- ◆ **Security Hub** aggregates all of them and runs posture checks against standards.

ON THE EXAM

GuardDuty detects. Detective explains. Security Hub aggregates. Naming which job a scenario needs picks the service.

A naming warning on Security Hub

- ◆ The old service is now called **AWS Security Hub CSPM**. Standards, controls, and aggregated findings.
- ◆ A new, larger **AWS Security Hub** now exists, with attack-path analysis and paid plans. CSPM sits inside it.
- ◆ The exam's in-scope list says **AWS Security Hub**, and means the posture-management behaviour described here.
- ◆ Answer with aggregation, standards and controls. That is true of both, and it is what questions test.

ON THE EXAM

Another rename that study material has not caught up with, like QuickSight becoming Amazon Quick. The exam behaviour is unchanged.

Querying and responding

- ◆ **Athena over the log archive bucket** is the standard way to query years of CloudTrail cheaply.
- ◆ **CloudWatch Logs Insights** for recent operational logs. **OpenSearch** when you need dashboards and full-text search.
- ◆ **EventBridge** is how findings become action: a GuardDuty finding triggers a Lambda or a runbook.
- ◆ CloudTrail Lake exists and entered maintenance in 2026. Do not reach for it as a new design.

ON THE EXAM

Querying archived logs occasionally is Athena. Searching live logs constantly is OpenSearch. The frequency decides it.

Reading the scenario

THE SCENARIO SAYS

An account admin disabled logging

Logs must be provably unaltered for years

Who made this change?

What did it look like before the change?

Security team needs a view without management access

Respond automatically to a finding

IT IS POINTING AT

Organisation trail, plus an SCP

Object Lock compliance mode, plus validation

CloudTrail

AWS Config

Delegated administrator

EventBridge to Lambda or a runbook

ON THE EXAM

Ask whether the gap is collection, protection, detection or query. Naming the missing job picks the service.

During an incident review, Meridian Freight discovers that an administrator in a workload account disabled CloudTrail for two hours and deleted the log files from that account's S3 bucket. Each account currently configures its own trail.

The security team must guarantee this cannot happen again in any of the 140 accounts.

What should the solutions architect implement?

- ☐ A A Config rule that detects when CloudTrail is disabled and re-enables it
- ☐ B An organisation trail delivering to a separate Log Archive account, with an SCP denying trail changes
- ☐ C Enable S3 versioning on each account's log bucket
- ☐ D Require MFA before CloudTrail can be disabled

◆ PAUSE AND DECIDE

What should the solutions architect implement?

A Config rule with remediation

Detective. It notices after the gap exists, and those two hours are already unlogged and gone.

C Versioning

Protects against overwrite by keeping old versions, and an administrator with delete permission can remove versions too.

B Organisation trail plus SCP

Member accounts cannot alter an organisation trail, the logs land where they cannot reach, and the SCP closes the rest.

D Require MFA

Raises the bar for an attacker and none at all for the legitimate administrator who did this, who has MFA.

THE SIGNAL

Guarantee and cannot happen again are preventive words. They eliminate every detective option, however fast it remediates.

A financial regulator requires seven years of audit logs, and requires the company to demonstrate that no log could have been altered or deleted during that period, by anyone, including the cloud team.

Logs are already delivered to a dedicated Log Archive account.

What should the solutions architect add?

- ☐ A S3 Object Lock in governance mode with a seven-year retention period
- ☐ B S3 Object Lock in compliance mode, plus CloudTrail log file integrity validation
- ☐ C A lifecycle policy transitioning logs to Glacier Deep Archive after 90 days
- ☐ D Cross-Region replication of the log bucket to a second Region

◆ PAUSE AND DECIDE

What should the solutions architect add?

A Governance mode

The sharpest distractor. Governance mode can be overridden by a user with the right permission, which is precisely the cloud team.

C Lifecycle to Deep Archive

Sensible for cost over seven years and orthogonal to the requirement. Cheap storage is still deletable storage.

B Compliance mode plus validation

Compliance mode cannot be overridden by anyone, root included. Digest files then let the company demonstrate integrity rather than assert it.

D Cross-Region replication

Protects against losing a Region. A deletion request replicates as a deletion, so it does not protect against deliberate destruction.

THE SIGNAL

Including the cloud team is the phrase that separates the two Object Lock modes. Governance exists to be overridden; compliance does not.

A production outage is traced to a security group that stopped allowing database traffic. The team needs to know what the rules were before the change, who made it, and whether any other security group in the estate has the same problem now. CloudTrail, Config and CloudWatch are all enabled organisation-wide.

Which services answer those three questions, in order?

- | | |
|---|---|
| ☐ A Config, CloudTrail, Config | ☐ B CloudTrail, Config, CloudWatch |
| ☐ C CloudWatch, CloudTrail, Config | ☐ D Config, Config, CloudTrail |

◆ PAUSE AND DECIDE

Which services answer those three questions, in order?

- A

 Config, CloudTrail, Config
Prior state is Config's configuration history. Who made the call is CloudTrail. Estate-wide current state is a Config advanced query.
- B

 CloudTrail, Config, CloudWatch
Inverts the first two, and CloudWatch holds metrics and logs rather than a searchable inventory of resource configuration.
- C

 CloudWatch, CloudTrail, Config
CloudWatch cannot tell you what a security group's rules were. It never recorded them.
- D

 Config, Config, CloudTrail
Right about state twice, and CloudTrail is the identity question rather than the inventory one.

THE SIGNAL

Prior state and current state are both Config. Only the who question belongs to CloudTrail.

A security team of six must monitor findings across 200 accounts. Policy forbids them from holding credentials in the management account. They also want GuardDuty and Security Hub enabled automatically in every new account.

Today they are emailed a spreadsheet of findings each week.

What should the solutions architect recommend?

- ☐ A Grant the security team a cross-account role into all 200 accounts
- ☐ B Register a security account as delegated administrator for GuardDuty and Security Hub, with auto-enable for new accounts
- ☐ C Give the security team read-only access to the management account
- ☐ D Export findings from each account to a central S3 bucket and query with Athena

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Cross-account roles

Six people switching between 200 accounts to read findings. It works and it does not aggregate anything.

C Read-only in the management account

Directly contradicts the stated policy, and read-only there still would not aggregate member account findings.

B Delegated administrator

One console showing every account's findings, no management account credentials, and auto-enable covers accounts created next month.

D Export and query

Rebuilds aggregation the services already do, and swaps a live console for a query the team must remember to run.

THE SIGNAL

Three requirements: one view, no management credentials, automatic for new accounts. Delegated administration is the only option meeting all three.

An auditor asks for a list of every S3 bucket across all accounts and Regions that currently allows public access, and asks how the company would produce the same list weekly without manual work.

An organisation trail and a Config aggregator are both in place.

What should the solutions architect propose?

- ☐ A Query CloudTrail in Athena for PutBucketAcl and PutBucketPolicy calls
- ☐ B Run a Config advanced query against the aggregator, and deploy an organisation Config rule for ongoing evaluation
- ☐ C Enable Macie in every account and review its findings
- ☐ D Write a Lambda function that lists every bucket in every account weekly

◆ PAUSE AND DECIDE

What should the solutions architect propose?

A CloudTrail in Athena

Finds calls that changed permissions, not buckets that are public now. A bucket made public before the trail existed never appears.

C Macie

Finds sensitive data inside buckets. It answers what is in them, not who can reach them.

B Config query plus org rule

The aggregator already holds current state for every account and Region, and the organisation rule keeps evaluating it continuously.

D Custom Lambda

Builds and maintains a weekly job to reproduce a query the aggregator can already answer.

THE SIGNAL

Currently allows is a state question, so it is Config. CloudTrail would only find buckets whose permissions changed while it was watching.

GuardDuty in the delegated administrator account raises findings for compromised EC2 credentials several times a year. The current process is that an analyst reads the finding the next working day and manually isolates the instance.

The security team wants isolation to happen within minutes, at any hour, across all accounts.

What should the solutions architect implement?

- A A CloudWatch alarm on the GuardDuty findings metric, notifying an on-call rota
- B An EventBridge rule matching the finding type, invoking a Lambda function that applies an isolation security group
- C Enable Detective so analysts can investigate faster
- D Increase GuardDuty finding frequency to fifteen minutes

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

 Alarm and on-call rota
Wakes a human faster. Within minutes at any hour is a machine requirement, and paging six people several times a year is expensive.
- B

 EventBridge to Lambda
Findings raise events immediately. A rule can match the type and act automatically, in every account, without anyone awake.
- C

 Enable Detective
Speeds up investigation after isolation. Valuable, and it takes no action, so nothing is contained any sooner.
- D

 Raise finding frequency
Changes how often findings are published, not what happens next. The delay is the human, not the detection.

THE SIGNAL

Within minutes at any hour is an automation requirement. Any option ending in a human reading something cannot meet it.

What to carry out of this module

- ◆ **An organisation trail cannot be altered by member accounts.** A per-account trail can.
- ◆ **Governance mode can be overridden; compliance mode cannot.** Regulators mean compliance.
- ◆ **Config for state, CloudTrail for identity, CloudWatch for performance.** Past and present state are both Config.
- ◆ GuardDuty detects, Detective explains, Security Hub aggregates, EventBridge acts.

ON THE EXAM

Ask which of the four jobs is missing: aggregate, make immutable, detect, or query. Collection is usually already there.